If you must include user input in error messages, then consider sanitizing it first using a robust library such as the OWASP HTML Sanitizer (https://github.com/OWASP/java-html-sanitizer) or JSON Sanitizer. This will remove a wide variety of potential XSS attack vectors.

EXERCISES

4. Which security header should be used to prevent web browsers from ignoring the `Content-Type` header on a response?

a) `Cache-Control`

b) `Content-Security-Policy`

c) `X-Frame-Options: deny`

d) `X-Content-Type-Options: nosniff`

e) `X-XSS-Protection: 1; mode=block`

5. Suppose that your API can produce output in either JSON or XML format, according to the `Accept` header sent by the client. Which of the following should you *not* do? There may be more than one correct answer.

a) Set the `X-Content-Type-Options` header.

b) Include un-sanitized input values in error messages.

c) Produce output using a well-tested JSON or XML library

d) Ensure the Content-Type is correct on any default error responses.